

TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI
KHOA CÔNG NGHỆ THÔNG TIN

-----o0o-----



BÁO CÁO BÀI TẬP LỚN
PHÂN TÍCH THIẾT KẾ YÊU CẦU – PROJECT 1
NHÓM 13
XÂY DỰNG HỆ THỐNG GIÁM SÁT MẠNG VỚI
WAZUH

Giảng viên hướng dẫn:

Giảng viên: *Nguyễn Quốc Tuấn*

Sinh viên thực hiện:

1	Lê Đình Dũng	211240089
2	Chu Ngọc Anh	211210503
3	Trần Quang Anh	211210126
4	Nguyễn Quốc Tú	211200619

Hà Nội, Tháng 09 Năm 2024

-----o0o-----

LỜI MỞ ĐẦU

Trong kỷ nguyên số, khi công nghệ thông tin trở thành xương sống của mọi hoạt động, từ kinh doanh, giáo dục đến y tế và chính phủ, an ninh mạng nổi lên như một thách thức cấp bách. Các cuộc tấn công mạng ngày càng tinh vi và đa dạng, đe dọa nghiêm trọng đến tính bảo mật, toàn vẹn và khả năng sẵn sàng của hệ thống thông tin. Từ những mã độc tống tiền (ransomware) làm tê liệt hoạt động kinh doanh, đến các cuộc tấn công từ chối dịch vụ (DDoS) gây gián đoạn dịch vụ trực tuyến, hay những lỗ hổng zero-day âm thầm khai thác thông tin nhạy cảm, tất cả đều tạo nên một bức tranh đầy thách thức về an ninh mạng.

Giữa bối cảnh đó, giám sát an ninh mạng đóng vai trò then chốt trong việc bảo vệ các tổ chức khỏi những mối đe dọa tiềm ẩn. Một hệ thống giám sát hiệu quả không chỉ giúp phát hiện sớm các cuộc tấn công, mà còn cung cấp thông tin chi tiết về hoạt động của hệ thống, hỗ trợ quá trình điều tra và ứng phó sự cố, đồng thời giúp các tổ chức tuân thủ các quy định về bảo mật. Tuy nhiên, việc xây dựng và vận hành một hệ thống giám sát toàn diện đòi hỏi sự đầu tư đáng kể về công nghệ, kiến thức chuyên môn và nguồn lực.

Báo cáo này sẽ tập trung vào việc nghiên cứu và triển khai một hệ thống giám sát an ninh mạng hiệu quả và tiết kiệm chi phí dựa trên nền tảng Wazuh - một giải pháp mã nguồn mở mạnh mẽ. Nhóm 13 chúng em sẽ đi sâu vào phân tích các yêu cầu giám sát, thiết kế kiến trúc hệ thống, và đánh giá hiệu quả của Wazuh trong việc bảo vệ hệ thống thông tin khỏi các mối đe dọa an ninh mạng.

Nhân đây, chúng em xin chân thành cảm ơn sự giúp đỡ tận tình của giảng viên, thầy Nguyễn Quốc Tuấn. Song, do kiến thức và kinh nghiệm còn nhiều hạn chế, việc tìm hiểu và nghiên cứu về đề tài này của nhóm chúng em sẽ không tránh được những thiếu sót. Rất mong được thầy và các bạn đóng góp ý kiến để đề tài của chúng em được hoàn thiện hơn.

Chúng em xin chân thành cảm ơn!

MỤC LỤC

LỜI MỞ ĐẦU	2
CHƯƠNG I. TỔNG QUAN VỀ HỆ THỐNG GIÁM SÁT AN NINH MẠNG.....	5
1.1. Định nghĩa và vai trò:	5
1.2. Các loại hình giám sát:.....	5
1.3. Các mối đe dọa và thách thức an ninh mạng phổ biến:.....	5
CHƯƠNG II. KHẢO SÁT VÀ PHÂN TÍCH THIẾT KẾ YÊU CẦU.....	6
2.1. Phương pháp khảo sát và đối tượng khảo sát:	6
2.2. Mô hình hệ thống	8
2.2.1 Các yêu cầu chức năng	8
2.2.2 Các yêu cầu phi chức năng	9
CHƯƠNG III. GIỚI THIỆU VỀ WAZUH.....	10
3.1. Tổng quan về XDR và SIEM:	10
3.1.1. XDR là gì ?	10
3.1.2. SIEM là gì ?.....	11
3.2. Những tính năng nổi bật của Wazuh:	12
3.2.1. Thu thập và Phân tích Nhật ký (SIEM):	12
3.2.2. Phát hiện và Phản hồi Mối đe dọa Nâng cao (XDR):	12
3.2.3. Các Tính năng Bảo mật khác:	13
3.2.4. Tích hợp Linh hoạt và Khả năng Mở rộng:.....	13
CHƯƠNG IV. PHÂN TÍCH THIẾT KẾ HỆ THỐNG.....	14
4.1. Kiến trúc và các thành phần của Wazuh:	14
4.1.1. Wazuh Agent:	14
4.1.2. Wazuh Manager (Server):	14
4.1.3. Wazuh Indexer:	15
4.1.4. Wazuh Dashboard:.....	15
4.1.5. Các thành phần hỗ trợ khác:	15
4.2. Wazuh hoạt động như thế nào ?	16
Bước 1. Thu thập dữ liệu:.....	16
Bước 2. Truyền dữ liệu:	16
Bước 3. Xử lý và phân tích dữ liệu:.....	16
Bước 4. Lưu trữ và lập chỉ mục dữ liệu:	17
Bước 5. Trực quan hóa và tương tác:	17
CHƯƠNG V. SO SÁNH WAZUH VỚI CÁC GIẢI PHÁP KHÁC.....	18
5.1. Một số giải pháp khác:.....	18
5.1.1. Splunk Enterprise Security	18
5.1.2. OSSEC.....	19

5.1.3 <i>Alien Vault OSSIM</i>	20
5.2. So sánh và đánh giá:	21
5.2.1. <i>So sánh</i>	21
5.2.2. <i>Đánh giá chi tiết từng giải pháp</i>	24

CHƯƠNG I. TỔNG QUAN VỀ HỆ THỐNG GIÁM SÁT AN NINH MẠNG

1.1. Định nghĩa và vai trò:

- Giám sát an ninh mạng là quá trình thu thập, phân tích và đánh giá thông tin về hoạt động của hệ thống, nhằm phát hiện các dấu hiệu bất thường hoặc các mối đe dọa tiềm ẩn.
- Một hệ thống giám sát hiệu quả không chỉ giúp bảo vệ tài sản thông tin quan trọng, mà còn đảm bảo tính liên tục của hoạt động kinh doanh, nâng cao năng lực phục hồi sau sự cố, và tuân thủ các quy định về bảo mật.
- Tuy nhiên, việc xây dựng và vận hành một hệ thống giám sát toàn diện đòi hỏi sự đầu tư đáng kể về công nghệ, kiến thức chuyên môn, và nguồn lực.

1.2. Các loại hình giám sát:

Các loại hình giám sát an ninh mạng phổ biến bao gồm:

- **Giám sát mạng:** Theo dõi lưu lượng mạng, phát hiện các hoạt động bất thường hoặc các cuộc tấn công mạng.
- **Giám sát hệ thống:** Quản lý và kiểm soát các thay đổi trong hệ thống, phát hiện các hành vi đáng ngờ hoặc các lỗ hổng bảo mật.
- **Giám sát ứng dụng:** Theo dõi hoạt động của các ứng dụng, phát hiện các lỗi, sự cố hoặc các cuộc tấn công nhắm vào ứng dụng.

1.3. Các mối đe dọa và thách thức an ninh mạng phổ biến:

Kết quả khảo sát trên cho thấy các mối đe dọa và thách thức an ninh mạng mà tổ chức đang phải đối mặt bao gồm:

- **Tấn công mạng:** Các cuộc tấn công từ bên ngoài như malware, phishing, SQL injection, và tấn công DDoS ngày càng gia tăng về số lượng và mức độ tinh vi.
- **Lỗ hổng bảo mật:** Các lỗ hổng trong phần mềm, cấu hình sai, và thiếu cập nhật bảo mật tạo ra những điểm yếu mà kẻ tấn công có thể khai thác.
- **Hành vi bất thường của người dùng:** Các hoạt động bất thường của người dùng nội bộ, như truy cập trái phép, sử dụng tài nguyên quá mức, hoặc cố tình gây hại cho hệ thống, cũng là một mối đe dọa đáng kể.
- **Sự cố hệ thống:** Lỗi phần cứng, mất điện, hoặc các sự cố kỹ thuật khác có thể gây gián đoạn hoạt động và mất mát dữ liệu.

CHƯƠNG II. KHẢO SÁT VÀ PHÂN TÍCH THIẾT KẾ YÊU CẦU

2.1. Phương pháp khảo sát và đối tượng khảo sát:

- Để thu thập thông tin và đánh giá nhu cầu giám sát an ninh mạng, chúng em đã tiến hành khảo sát bằng cách kết hợp giữa phỏng vấn trực tiếp và khảo sát trực tuyến.
- Đối tượng khảo sát bao gồm các quản trị viên hệ thống, chuyên gia an ninh mạng của các doanh nghiệp và tổ chức.

** Các chủ đề phỏng vấn:

- A. Nguy cơ chính mà doanh nghiệp phải đối mặt trong lĩnh vực an ninh mạng ngày nay.
- B. Tầm quan trọng của đầu tư vào an ninh mạng đối với mọi tổ chức.
- C. Biện pháp an ninh linh hoạt và tiên tiến để đối phó với mối đe dọa hiện nay.
- D. Duy trì môi trường an toàn trên mạng trong bối cảnh công nghệ phát triển.
- E. Cải thiện nhận thức về an ninh mạng trong cộng đồng người dùng cuối.

** Câu trả lời phía đối tượng được khảo sát:

- A. Nguy cơ chính mà doanh nghiệp phải đối mặt trong lĩnh vực an ninh mạng ngày nay.

• Anh Quang (35 tuổi, Chuyên viên An ninh mạng của Ngân hàng MB):
“ Trong lĩnh vực an ninh mạng hiện nay, doanh nghiệp phải đối mặt với nhiều nguy cơ, bao gồm tấn công malware, phishing, tấn công từ bên ngoài, rò rỉ dữ liệu, và các mối đe dọa liên quan đến trí tuệ nhân tạo và IoT. Đặc biệt, các cuộc tấn công mạng ngày càng phức tạp và tinh vi, đe dọa đến tính bảo mật và sự tin cậy của hệ thống thông tin.”

• Chị Thảo (28 tuổi, Quản trị viên Hệ thống của Giao hàng Tiết kiệm):
“ Trong lĩnh vực giao hàng và vận chuyển, một trong những nguy cơ chính là tấn công vào hệ thống theo dõi vận chuyển, đe dọa an toàn thông tin khách hàng và hàng hóa. Hơn nữa, mối đe dọa từ việc giả mạo thông tin vận chuyển và tấn công từ bên ngoài cũng là những vấn đề cần được chú ý.”

B. Tầm quan trọng của đầu tư vào an ninh mạng đối với mọi tổ chức.

- Anh Quang (35 tuổi, Chuyên viên An ninh mạng của Ngân hàng MB):
“Đầu tư vào an ninh mạng không chỉ đảm bảo bảo vệ thông tin quan trọng của tổ chức mà còn duy trì uy tín và niềm tin của khách hàng. Việc bảo vệ dữ liệu và hệ thống mạng không chỉ giúp tránh khỏi mất mát về tài chính mà còn ngăn chặn các hậu quả tiêu cực đối với hoạt động kinh doanh và uy tín thương hiệu.”
- Chị Thảo (28 tuổi, Quản trị viên Hệ thống của Giao hàng Tiết kiệm):
“Đầu tư vào an ninh mạng không chỉ bảo vệ dữ liệu khách hàng mà còn đảm bảo tính minh bạch và an toàn trong quá trình vận chuyển. Việc xây dựng hệ thống theo dõi và bảo mật chặt chẽ không chỉ tạo niềm tin cho khách hàng mà còn giữ cho hoạt động kinh doanh suôn sẻ.”

C. Biện pháp an ninh linh hoạt và tiên tiến để đối phó với mối đe dọa hiện nay.

- Anh Quang (35 tuổi, Chuyên viên An ninh mạng của Ngân hàng MB):
“Để đáp ứng được sự phức tạp của các mối đe dọa hiện nay, các biện pháp an ninh mạng cần kết hợp cả công nghệ và nhân lực. Đầu tiên, cần áp dụng các giải pháp bảo mật tiên tiến như AI và machine learning để phát hiện và ngăn chặn tấn công. Thứ hai, việc liên tục cập nhật và nâng cấp hệ thống an ninh cũng rất quan trọng để đảm bảo tính linh hoạt và khả năng phản ứng nhanh chóng trước các mối đe dọa mới.”
- Chị Thảo (28 tuổi, Quản trị viên Hệ thống của Giao hàng Tiết kiệm):
“Để đối phó với các mối đe dọa hiện nay, cần áp dụng các giải pháp an ninh mạng tiên tiến như mã hóa dữ liệu, kiểm soát truy cập, và theo dõi hệ thống liên tục. Đồng thời, việc đào tạo nhân viên về an ninh mạng và xây dựng kế hoạch phản ứng khẩn cấp cũng rất quan trọng.”

D. Duy trì môi trường an toàn trên mạng trong bối cảnh công nghệ phát triển.

- Anh Quang (35 tuổi, Chuyên viên An ninh mạng của Ngân hàng MB):
“Để duy trì môi trường an toàn trên mạng, chúng ta cần liên tục theo dõi và đánh giá các rủi ro, đào tạo nhân viên về an ninh mạng, thúc đẩy văn hóa an toàn thông tin trong tổ chức, thực hiện kiểm tra bảo mật định kỳ, và đầu tư vào giải pháp bảo mật hiệu quả.”

- Chị Thảo (28 tuổi, Quản trị viên Hệ thống của Giao hàng Tiết kiệm):
“ Để duy trì môi trường an toàn trên mạng, cần thường xuyên đánh giá và cập nhật các biện pháp bảo mật, thúc đẩy tinh thần an toàn thông tin trong tổ chức, và tổ chức các buổi đào tạo để nâng cao nhận thức về an ninh mạng cho nhân viên. ”

E. Cải thiện nhận thức về an ninh mạng trong cộng đồng người dùng cuối.

- Anh Quang (35 tuổi, Chuyên viên An ninh mạng của Ngân hàng MB):
“ Để giảm thiểu rủi ro cho các tổ chức và cá nhân, cần tăng cường giáo dục và tư vấn an ninh mạng cho người dùng cuối. Việc nâng cao nhận thức về các mối đe dọa mạng, hướng dẫn về cách bảo vệ thông tin cá nhân và doanh nghiệp, và thúc đẩy sử dụng các biện pháp bảo mật cơ bản như mật khẩu mạnh và cập nhật phần mềm đều rất quan trọng.”
- Chị Thảo (28 tuổi, Quản trị viên Hệ thống của Giao hàng Tiết kiệm):
“ Để giảm thiểu rủi ro cho khách hàng và tổ chức, cần tăng cường giáo dục và nhận thức về an ninh mạng trong cộng đồng người dùng cuối. Việc hướng dẫn khách hàng về cách bảo vệ thông tin cá nhân, xác thực giao dịch và thông tin vận chuyển là rất quan trọng để tạo ra một môi trường giao dịch an toàn và tin cậy.”

2.2. Mô hình hệ thống

2.2.1 Các yêu cầu chức năng

a. Quản lý và xử lý dữ liệu:

- Yêu cầu thu thập dữ liệu theo thời gian thực (thời gian thu thập và xử lý dữ liệu ít hơn 5 phút)
- Tổng hợp dữ liệu về một nơi lưu trữ và chuẩn hóa theo một định dạng chung
- Kết hợp các sự kiện và dữ liệu liên quan để xác định chính xác một sự cố hoặc đưa ra một cảnh báo chính xác
- Cho phép truy cập trực tuyến theo phân quyền các log thu thập được và các dữ liệu đã được xử lý
- Có thể lưu trữ log, phục vụ cho báo cáo thống kê, điều tra về sau

b. Giám sát và phân tích

- Yêu cầu thực hiện việc giám sát các cuộc tấn công theo thời gian thực
- Cung cấp khả năng giám sát, phát hiện các cuộc tấn công trên lớp mạng và các thiết bị đầu cuối
- Cung cấp khả năng giám sát, phát hiện trên các thiết bị mạng, thiết bị bảo mật
- Threat intelligence: Kết hợp dữ liệu với các nguồn thông tin từ bên thứ ba để lấy các dữ liệu về mối đe dọa, lỗ hổng và các cuộc tấn công

c. Khả năng phòng thủ và phản ứng

- Phòng thủ chủ động: ngăn chặn các thiết bị có hành vi bất thường
- Phân quyền linh hoạt: cho phép phân quyền từng loại chức năng theo dải mạng IP
- Ghi lại Log: ghi lại toàn bộ Log đăng nhập, hoạt động của nhân viên SOC
- Sao lưu và khôi phục: có khả năng sao lưu và khôi phục hoạt động của hệ thống sau sự cố

d. Quy trình làm việc và tự động hóa

- Cho phép kết hợp với các giải pháp khác
- Kết nối, chia sẻ với cục ATTT
- Khả năng mở rộng quy mô dễ dàng và triển khai hệ thống với nhiều quy mô khác nhau

2.2.2 Các yêu cầu phi chức năng

a. Quy trình

- Quy trình quản lý, vận hành của hệ thống phải đảm bảo vận hành hoạt động bình thường, ổn định, có tính chịu lỗi cao 24/7, 365 ngày với các hệ thống quan trọng
- Sẵn sàng khôi phục lại bình thường sau khi xảy ra sự cố

b. Con người

- Có kiến thức chuyên sâu về mạng, lập trình, mã độc, biết ứng phó, giải quyết nhanh chóng các cuộc tấn công
- Sử dụng thành thạo các công cụ, hệ thống an ninh mạng phổ biến.
- Có kiến thức về bảo mật, pentest, khai thác lỗ hổng
- Đảm bảo trách nhiệm, kỷ luật với tổ chức, luôn sẵn sàng ngay khi có sự cố

CHƯƠNG III. GIỚI THIỆU VỀ WAZUH

wazuh.

Wazuh là một nền tảng bảo mật mã nguồn mở toàn diện, được thiết kế để giúp các tổ chức bảo vệ hệ thống và dữ liệu của họ khỏi các mối đe dọa an ninh mạng ngày càng gia tăng. Với sự kết hợp giữa khả năng phát hiện và phản ứng mở rộng (XDR) và quản lý thông tin và sự kiện bảo mật (SIEM), Wazuh cung cấp một giải pháp giám sát, phân tích và ứng phó sự cố tập trung, giúp các doanh nghiệp chủ động đối phó với các cuộc tấn công tinh vi.

3.1. Tổng quan về XDR và SIEM:

3.1.1. XDR là gì ?



- XDR (Extended Detection and Response) đại diện cho một bước tiến vượt bậc trong lĩnh vực giám sát và ứng phó bảo mật. Vượt qua các giải pháp truyền thống, XDR tích hợp dữ liệu từ đa dạng nguồn như điểm cuối, mạng, đám mây, email và danh tính, mang đến khả năng hiển thị toàn diện và phát hiện mối đe dọa trên diện rộng.

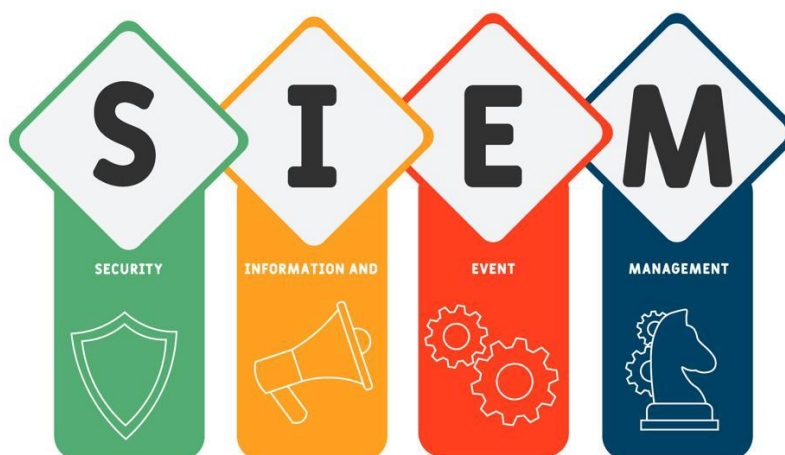
- Sức mạnh của XDR nằm ở khả năng tương quan và phân tích nâng cao, tận dụng trí tuệ nhân tạo (AI) và học máy để liên kết các sự kiện bảo mật rời rạc, từ đó phát hiện các mối đe dọa phức tạp và chuỗi tấn công đa chiều. Hơn

nữa, XDR cho phép tự động hóa các quy trình ứng phó, giảm thiểu đáng kể thời gian phản hồi và tác động của các cuộc tấn công.

+ Chức năng chính của XDR:

- Tích hợp và tương quan dữ liệu từ nhiều nguồn.
- Phát hiện và ngăn chặn mối đe dọa bằng AI và học máy.
- Điều tra và ứng phó sự cố nhanh chóng.
- Tự động hóa các quy trình ứng phó.
- Báo cáo và trực quan hóa dữ liệu bảo mật.

3.1.2. SIEM là gì ?



- SIEM (Security Information and Event Management) đóng vai trò trung tâm trong việc quản lý thông tin và sự kiện bảo mật. Bằng cách thu thập và lưu trữ nhật ký từ nhiều nguồn khác nhau, SIEM tạo ra một kho dữ liệu tập trung, làm nền tảng cho phân tích và điều tra bảo mật.

- Thông qua các quy tắc tương quan tình vi, SIEM có khả năng xác định các mối quan hệ giữa các sự kiện bảo mật, từ đó phát hiện các mẫu tấn công tiềm ẩn. Bên cạnh đó, SIEM còn cung cấp các báo cáo chi tiết, hỗ trợ các tổ chức chứng minh sự tuân thủ các quy định bảo mật.

+ Chức năng chính của SIEM:

- Thu thập và tổng hợp dữ liệu nhật ký từ nhiều nguồn.
- Tương quan và phân tích sự kiện để phát hiện mối đe dọa.
- Cảnh báo và thông báo về các sự kiện bảo mật.
- Báo cáo và trực quan hóa tình trạng bảo mật.
- Lưu trữ và truy vấn dữ liệu lịch sử.
- Hỗ trợ tuân thủ các quy định bảo mật.

3.2. Những tính năng nổi bật của Wazuh:

Wazuh, một giải pháp tiên tiến trong lĩnh vực bảo mật, kết hợp liền mạch công nghệ XDR (Extended Detection and Response) và SIEM (Security Information and Event Management). Sự tích hợp độc đáo này tạo nên một hệ thống bảo mật toàn diện, cung cấp một loạt tính năng vượt trội:

3.2.1. Thu thập và Phân tích Nhật ký (SIEM):

- **Thu thập đa nguồn:** Wazuh thu thập nhật ký từ nhiều nguồn khác nhau, bao gồm hệ thống, ứng dụng, thiết bị mạng và nhiều hơn nữa, cung cấp một cái nhìn toàn diện về hoạt động của môi trường CNTT của bạn.
- **Phân tích chuyên sâu:** Thông qua phân tích và tương quan các sự kiện từ nhiều nguồn, Wazuh giúp bạn xác định các mối đe dọa tiềm ẩn, các mẫu tấn công và các hành vi bất thường.
- **Tìm kiếm và điều tra:** Với khả năng tìm kiếm và điều tra mạnh mẽ, Wazuh cho phép bạn nhanh chóng truy vết và phân tích các sự kiện bảo mật, hỗ trợ quá trình điều tra và xử lý sự cố.
- **Báo cáo và cảnh báo:** Wazuh cung cấp các báo cáo tùy chỉnh và cảnh báo theo thời gian thực, giúp bạn luôn nắm bắt được tình hình an ninh và kịp thời phản ứng trước các sự cố.

3.2.2. Phát hiện và Phản hồi Mối đe dọa Nâng cao (XDR):

- **Tương quan và phân tích dữ liệu đa chiều:** Wazuh không chỉ thu thập dữ liệu mà còn thực hiện tương quan và phân tích sâu giữa chúng, giúp phát hiện các mối đe dọa phức tạp và các mẫu tấn công ẩn mình.
- **Phát hiện mối đe dọa nâng cao:** Sử dụng các kỹ thuật tiên tiến như UEBA, học máy và phân tích mối đe dọa, Wazuh có khả năng nhận diện các cuộc tấn công tinh vi, bao gồm cả các mối đe dọa chưa từng được biết đến (zero-day).
- **Phản ứng tự động và điều phối:** Khi phát hiện mối đe dọa, Wazuh có thể tự động thực hiện các hành động phản hồi như cách ly máy tính bị nhiễm, chặn IP độc hại hoặc thực thi các quy trình khắc phục sự cố, giảm thiểu thời gian phản hồi và thiệt hại.
- **Khả năng hiển thị và điều tra tập trung:** Giao diện tập trung của Wazuh giúp bạn giám sát, phân tích và điều tra các sự cố bảo mật trên toàn hệ thống một cách dễ dàng và hiệu quả.

- **Bảo vệ khối lượng công việc đám mây và container:** Wazuh tích hợp với các dịch vụ đám mây và môi trường container, cho phép bạn giám sát và bảo vệ toàn diện các tài nguyên đám mây và ứng dụng container hóa.

3.2.3. Các Tính năng Bảo mật khác:

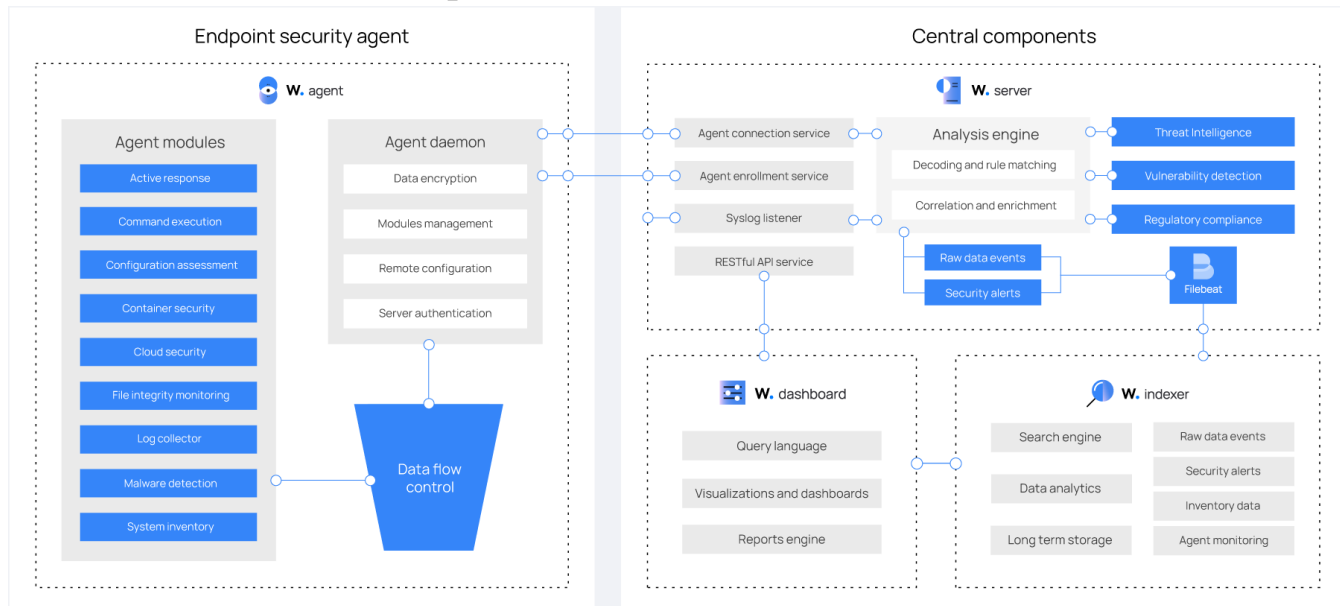
- **Phát hiện xâm nhập (IDS):** Giám sát hệ thống và phát hiện các hành vi bất thường hoặc xâm nhập không mong muốn.
- **Quản lý cấu hình và chính sách:** Đảm bảo tính tuân thủ chính sách bảo mật bằng cách kiểm tra và giám sát cấu hình thiết bị và phần mềm.
- **Phát hiện và xử lý mã độc:** Nhận diện và loại bỏ mã độc, bảo vệ hệ thống khỏi phần mềm độc hại.

3.2.4. Tích hợp Linh hoạt và Khả năng Mở rộng:

- **Kết nối đa dạng:** Wazuh có thể tích hợp với nhiều công cụ và nền tảng khác, cho phép bạn xây dựng một hệ sinh thái bảo mật toàn diện và hiệu quả.
- **API mở rộng:** API của Wazuh cho phép bạn tự động hóa các quy trình làm việc và tích hợp với các hệ thống khác, tăng cường khả năng quản lý và giám sát.
- **Mã nguồn mở:** Wazuh là một giải pháp mã nguồn mở, mang đến sự linh hoạt và khả năng tùy chỉnh cao, đáp ứng các yêu cầu cụ thể của từng tổ chức.

CHƯƠNG IV. PHÂN TÍCH THIẾT KẾ HỆ THỐNG

4.1. Kiến trúc và các thành phần của Wazuh:



Wazuh được thiết kế theo mô hình phân tán, bao gồm các thành phần chính và các thành phần hỗ trợ, làm việc cùng nhau để cung cấp khả năng giám sát và bảo mật toàn diện. Các thành phần của Wazuh gồm:

4.1.1. Wazuh Agent:

- Được cài đặt trên các điểm cuối (endpoints) cần giám sát.
- Thu thập dữ liệu nhật ký, sự kiện, thông tin bảo mật, cấu hình hệ thống, kết quả quét lỗ hổng, và dữ liệu về tính toàn vẹn của tập tin từ hệ thống cục bộ.
- Gửi dữ liệu đã thu thập về Wazuh Manager thông qua một kết nối an toàn và nhận các lệnh từ Wazuh Manager.

4.1.2. Wazuh Manager (Server):

- Thành phần trung tâm của hệ thống, thường được cài đặt trên một máy chủ chuyên dụng.
- Tiếp nhận dữ liệu từ các Wazuh Agent.
- Phân tích và tương quan dữ liệu để phát hiện các mối đe dọa, hành vi bất thường và các sự cố bảo mật.
- Cung cấp giao diện quản lý tập trung để cấu hình, giám sát và điều khiển toàn bộ hệ thống Wazuh.
- Có khả năng mở rộng linh hoạt với tính năng Clustering, cho phép dễ dàng thêm hoặc bớt các Worker node, đảm bảo khả năng xử lý hiệu quả cho các hệ thống lớn.

4.1.3. Wazuh Indexer:

- Chịu trách nhiệm lưu trữ, đánh dấu chỉ mục và hỗ trợ tìm kiếm dữ liệu đã qua xử lý.
- Có thể được cấu hình với nhiều Nodes để tối ưu hóa khả năng xử lý và truy vấn, đảm bảo hiệu suất cao và duy trì tính toàn vẹn của dữ liệu..

4.1.4. Wazuh Dashboard:

- Cung cấp giao diện đồ họa cho người dùng, giúp trực quan hóa dữ liệu và quản lý cảnh báo, báo cáo, cũng như tuân thủ dữ liệu.
- Hỗ trợ người dùng trong việc phân tích và phản ứng nhanh chóng với các cuộc tấn công thông qua giao diện thân thiện.
- Có khả năng tích hợp nhiều add-ons và plugins để tối ưu hóa việc xử lý và quản lý dữ liệu.

4.1.5. Các thành phần hỗ trợ khác:

- Wazuh Filebeat:

- Một tác nhân nhẹ được sử dụng để chuyển tiếp dữ liệu nhật ký từ các nguồn khác nhau đến Wazuh Manager hoặc Elastic Stack.
- Đặc biệt hữu ích trong các mô hình triển khai phân tán, nơi Wazuh Manager không thể trực tiếp kết nối đến tất cả các nguồn dữ liệu.

- Wazuh API:

- Cung cấp một giao diện lập trình ứng dụng (API) để tích hợp Wazuh với các công cụ và hệ thống khác.
- Cho phép tự động hóa các tác vụ, truy vấn dữ liệu và mở rộng chức năng của Wazuh.

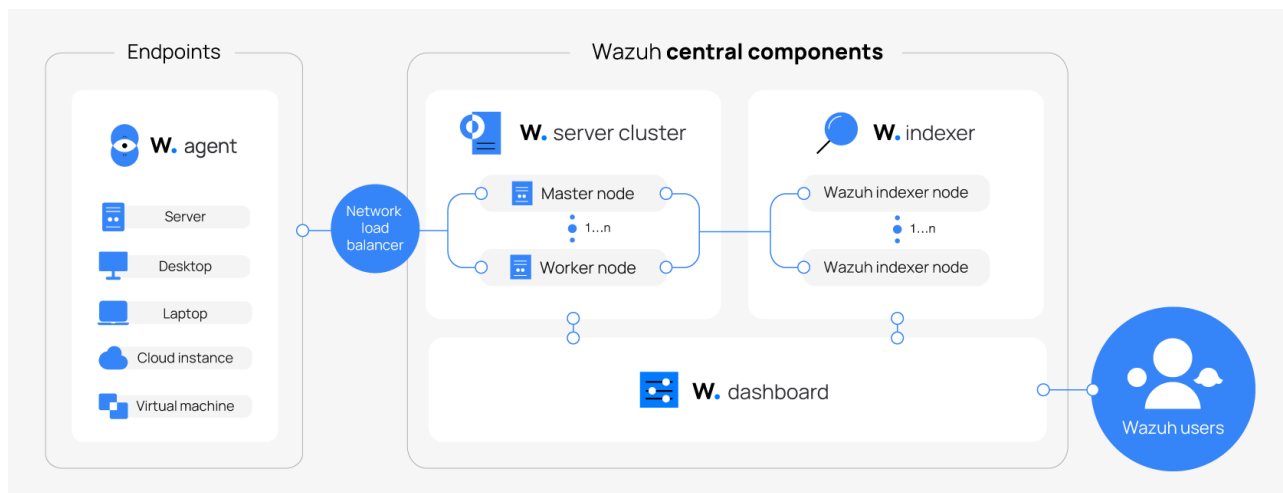
- Wazuh Ruleset:

- Một tập hợp các quy tắc được xác định trước để phát hiện các mối đe dọa và các hành vi bất thường.
- Các quy tắc này có thể được tùy chỉnh để phù hợp với môi trường và yêu cầu bảo mật cụ thể của tổ chức.

- Wazuh Modules:

- Các mô-đun mở rộng cung cấp các chức năng bổ sung như tích hợp với các công cụ bảo mật khác, giám sát các ứng dụng cụ thể hoặc thực hiện các tác vụ tùy chỉnh.

4.2. Wazuh hoạt động như thế nào ?



Quy trình hoạt động của Wazuh trải qua 5 bước:

Bước 1. Thu thập dữ liệu:

- **Wazuh Agent:** Các Wazuh Agent được cài đặt trên các điểm cuối (endpoints) khác nhau như máy chủ, máy tính để bàn, máy tính xách tay, instances đám mây và máy ảo. Chúng chịu trách nhiệm thu thập dữ liệu nhật ký hệ thống, nhật ký ứng dụng, thông tin về các tiến trình đang chạy, cấu hình hệ thống, kết quả quét lỗ hổng bảo mật và dữ liệu về tính toàn vẹn của tệp tin từ hệ thống cục bộ.

Bước 2. Truyền dữ liệu:

- **Wazuh Agent:** Các Agent sẽ gửi dữ liệu đã thu thập về Wazuh Manager thông qua một kết nối an toàn.
- **Network Load Balancer:** Trong trường hợp có nhiều Wazuh Manager, bộ cân bằng tải mạng sẽ phân phối đều lưu lượng dữ liệu từ các Agent đến các Manager, đảm bảo hệ thống hoạt động hiệu quả và cân bằng tải.

Bước 3. Xử lý và phân tích dữ liệu:

- Wazuh Server Cluster:

- **Master Node:** Đây là nút chính trong cụm máy chủ Wazuh, chịu trách nhiệm quản lý cấu hình của toàn bộ hệ thống và phân phối công việc cho các Worker Node.
- **Worker Node:** Các nút này tiếp nhận dữ liệu từ Master Node và thực hiện phân tích dữ liệu dựa trên các quy tắc (rules) được định nghĩa trước. Các quy

tắc này giúp phát hiện các mối đe dọa, hành vi bất thường và các thay đổi không mong muốn trong hệ thống.

Bước 4. Lưu trữ và lập chỉ mục dữ liệu:

- Wazuh Indexer:
- **Wazuh Indexer Node:** Dữ liệu sau khi được phân tích bởi các Worker Node sẽ được gửi đến Wazuh Indexer để lưu trữ và lập chỉ mục. Wazuh sử dụng Elasticsearch để thực hiện việc này, cho phép tìm kiếm và truy vấn dữ liệu một cách nhanh chóng và hiệu quả.

Bước 5. Trực quan hóa và tương tác:

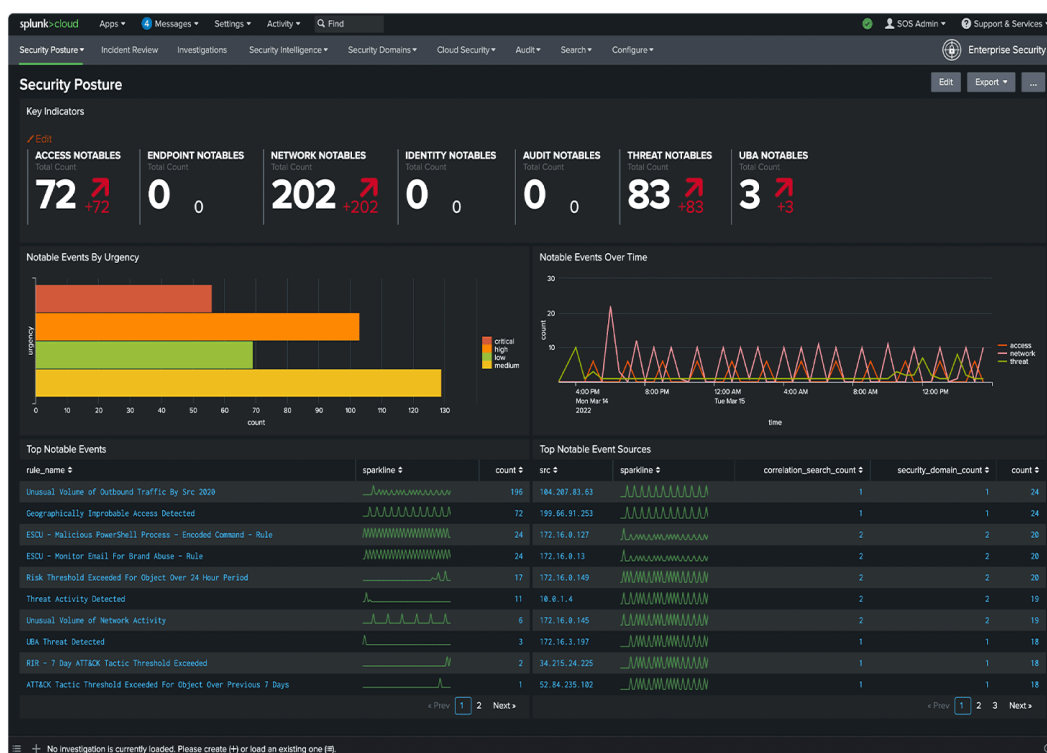
- Wazuh Dashboard:
- Dữ liệu được lưu trữ trong Wazuh Indexer được hiển thị trên Wazuh Dashboard. Giao diện này được xây dựng trên nền tảng Kibana, cung cấp các báo cáo, dashboard, biểu đồ trực quan, giúp người dùng dễ dàng giám sát và phân tích tình hình bảo mật.
- **Wazuh users:** Người dùng có thể xem các báo cáo, dashboard, thực hiện tìm kiếm, lọc, phân tích dữ liệu và nhận cảnh báo về các sự kiện bảo mật thông qua Wazuh Dashboard.

Quy trình này tạo nên một vòng tuần hoàn liên tục của việc thu thập, xử lý, lưu trữ và phân tích dữ liệu bảo mật, cho phép các tổ chức duy trì một hệ thống giám sát bảo mật toàn diện và phản ứng kịp thời với các mối đe dọa tiềm ẩn.

CHƯƠNG V. SO SÁNH WAZUH VỚI CÁC GIẢI PHÁP KHÁC

5.1. Một số giải pháp khác:

5.1.1. Splunk Enterprise Security

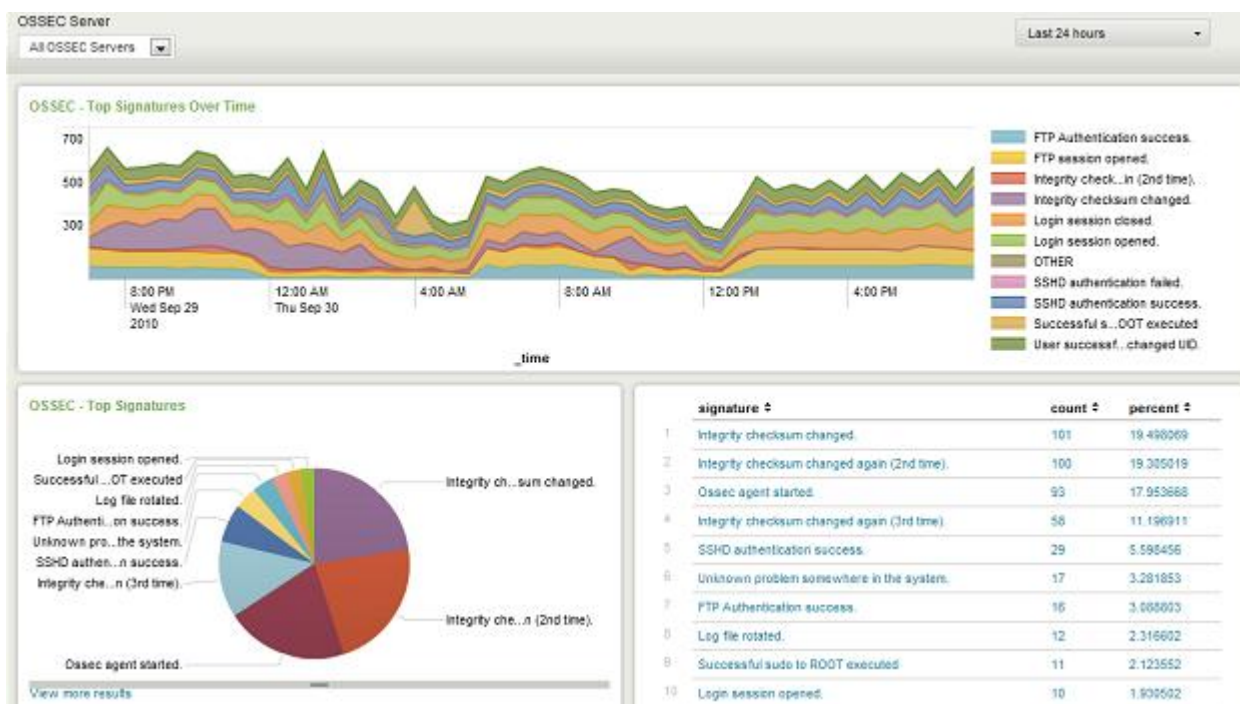


Một nền tảng SIEM (Security Information and Event Management) thương mại mạnh mẽ, cung cấp khả năng thu thập, phân tích và tương quan dữ liệu bảo mật từ nhiều nguồn khác nhau.

Splunk ES giúp tập hợp và phân tích dữ liệu từ nhiều nguồn khác nhau như tường lửa, hệ thống phát hiện xâm nhập, hệ thống ngăn ngừa xâm nhập, thiết bị mạng và các ứng dụng khác để tạo ra cái nhìn tổng quan về tình trạng bảo mật của hệ thống

Splunk ES hỗ trợ các tổ chức duy trì và báo cáo tuân thủ các quy định về an ninh như GDPR, HIPAA và PCI-DSS

5.1.2. OSSEC



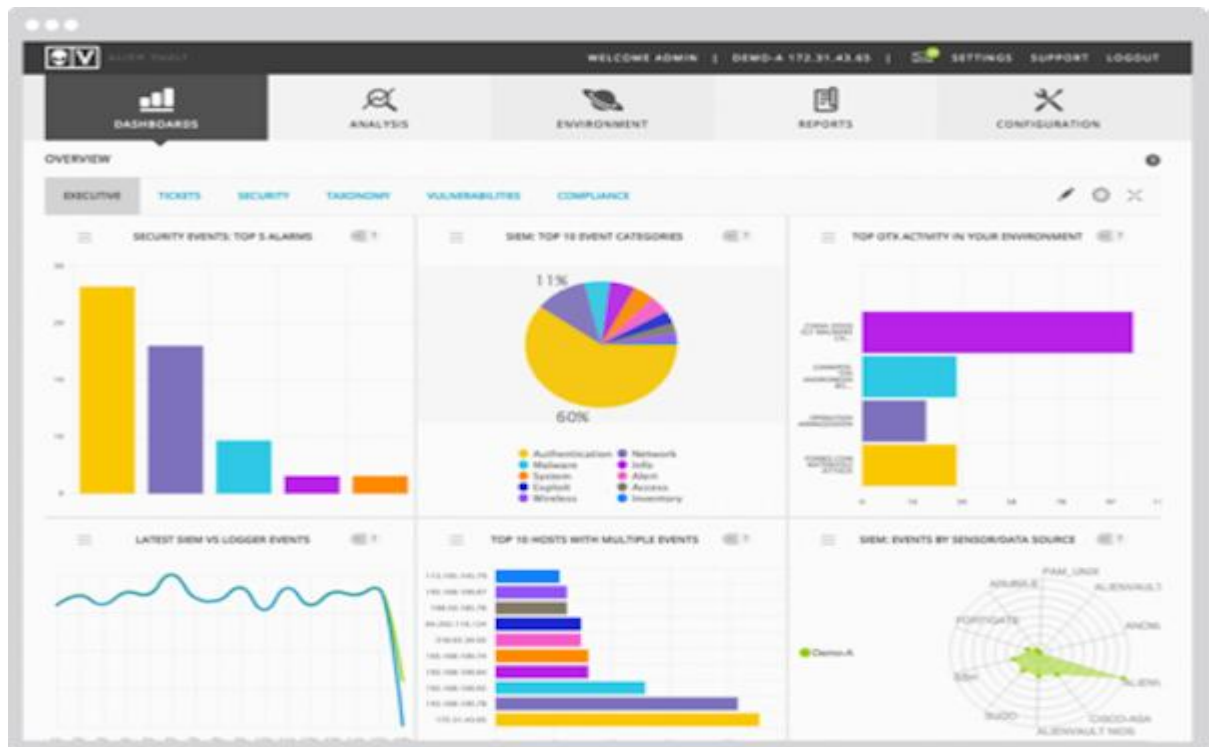
Một hệ thống phát hiện xâm nhập mã nguồn mở (HIDS) tập trung vào việc giám sát tính toàn vẹn của tập tin và phát hiện các thay đổi trái phép trong hệ thống.

Các chức năng chính của OSSEC bao gồm giám sát tệp, phân tích nhật ký, phát hiện rootkit, giám sát registry, tự động phản hồi

Mô hình kiến trúc của OSSEC hoạt động theo mô hình phân tán, trong đó các agent được cài đặt trên các máy chủ hệ thống đầu cuối, gửi dữ liệu về máy chủ OSSEC để phân tích

Đây là một công cụ mạnh mẽ, dễ triển khai và được sử dụng phổ biến trong các môi trường tài chính, chính phủ, y tế

5.1.3 Alien Vault OSSIM



Là một mã nguồn mở quản lý thông tin và sự kiện an ninh bao gồm tập hợp các công cụ được thiết kế để trợ giúp các nhân viên quản trị phát hiện và phòng chống xâm nhập

OSSIM bao gồm các thành phần SIEM chính, cụ thể là thu thập, xử lý và chuẩn hóa dữ liệu. Quan trọng nhất OSSIM có sự tương quan sự kiện

OSSIM tích hợp nhiều các mã nguồn mở vào hệ thống như: Snort, OSSEC, OpenVAS,...

5.2. So sánh và đánh giá:

5.2.1. So sánh

- Chúng ta so sánh Wazuh với ba giải pháp theo 10 tiêu chí như sau

Tiêu chí	Wazuh	Splunk Enterprise Security	OSSEC	AlienVault OSSIM
1. License	Mã nguồn mở (Elastic License)	Trả phí (Có bản dùng thử)	Mã nguồn mở (GPLv2)	Mã nguồn mở (GPLv3)
2. Triển khai				
2.1 Cloud	Có	Có	Có (Thông qua giải pháp của bên thứ ba)	Có (Thông qua giải pháp bên thứ 3)
2.2 On-premise	Có	Có	Có	Có
3. Hỗ trợ đa nền tảng (Windows, Linux, MacOS)	Có	Có	Có	Có (chủ yếu hỗ trợ Linux)
4. Khả năng thu thập và phân tích log				
4.1 Tích hợp với các nguồn logs	Rộng rãi	Rất rộng rãi (Hỗ trợ đa dạng nguồn dữ liệu)	Rộng rãi	Rộng rãi
4.2 Hỗ trợ các chuẩn định dạng logs	Đa dạng	Đa dạng	Đa dạng	Đa dạng
4.3 Phân tích logs theo thời gian thực	Có	Có	Có	Có
5. Phát hiện và phản ứng với mối đe dọa				

5.1 Các công cụ phát hiện mối đe dọa	Tích hợp sẵn các quy tắc phát hiện, hỗ trợ SIEM	Đa dạng, mạnh mẽ, hỗ trợ Machine Learning	Tích hợp sẵn các quy tắc phát hiện	Tích hợp với cơ sở dữ liệu threat intelligence của OTX(Open Threat Exchange)
5.2 Khả năng tùy chỉnh quy tắc phát hiện và cảnh báo	Có	Có (Linh hoạt, mạnh mẽ)	Có	Có (Linh hoạt)
5.3 Tính năng tự động phản hồi	Có (Giới hạn)	Có (Mạnh mẽ, tích hợp với SOAR)	Có (Giới hạn)	Có
6. Quản lý sự tuân thủ				
6.1 Tính năng báo cáo tuân thủ theo các tiêu chuẩn phổ biến	Có	Có (Mạnh mẽ, đa dạng)	Có (Giới hạn)	Có
6.2 Khả năng audit và theo dõi các hoạt động trong tổ chức	Có	Có (Mạnh mẽ)	Có	Có
6.3 Công cụ hỗ trợ phân tích sự cố bảo mật liên quan đến việc tuân thủ	Có	Có (Mạnh mẽ)	Có (Giới hạn)	Có (Mạnh mẽ)
7. Trực quan hóa và báo cáo				
7.1 Giao diện người dùng (UI) thân thiện và dễ sử dụng	Thân thiện	Rất thân thiện, dễ sử dụng	Giao diện web	Giao diện web

7.2 Khả năng tùy chỉnh báo cáo và dashboard	Có (Thông qua Kibana)	Có (Mạnh mẽ, linh hoạt)	Có (Giới hạn)	Có
7.3 Cung cấp cảnh báo tức thì với biểu đồ, đồ thị minh họa	Có (Thông qua Kibana)	Có (Đa dạng, trực quan)	Có (Cơ bản)	Có (Đa dạng, trực quan)
8. Khả năng tích hợp				
8.1 Hỗ trợ API cho các ứng dụng và công cụ bên ngoài	Có (linh hoạt)	Có (Rộng rãi, linh hoạt)	Có	Có
8.2 Khả năng tích hợp với các hệ thống quản lý bảo mật khác	Có	Có (Rộng rãi)	Có	Có
9. Use-case	phù hợp cho các tổ chức muốn một giải pháp mã nguồn mở linh hoạt với khả năng tùy chỉnh cao, có thể mở rộng cho các triển khai vừa và lớn	phù hợp cho các doanh nghiệp lớn cần xử lý lượng dữ liệu lớn và có ngân sách cao.	phù hợp nhất cho các triển khai nhỏ hoặc làm thành phần trong một stack bảo mật lớn hơn.	Phù hợp cho các tổ chức vừa và nhỏ muốn một giải pháp SIEM all-in-one mã nguồn mở và miễn phí. có thể mở rộng cho các triển khai vừa và lớn
10. Cộng đồng và hỗ trợ	có cộng đồng mã nguồn mở active	Splunk có hỗ trợ chuyên nghiệp 24/7 và cộng đồng người dùng lớn.	có cộng đồng mã nguồn mở active	có cộng đồng người dùng và hỗ trợ từ AT&T Cybersecurity

5.2.2. Đánh giá chi tiết từng giải pháp

- **Wazuh:** Giải pháp mã nguồn mở mạnh mẽ và linh hoạt, phù hợp cho các tổ chức vừa và lớn, đặc biệt khi ngân sách eo hẹp. Điểm mạnh là khả năng tùy chỉnh cao, tích hợp rộng rãi, và cộng đồng hỗ trợ lớn. Tuy nhiên, giao diện người dùng có thể chưa thân thiện bằng các giải pháp thương mại, và yêu cầu kiến thức kỹ thuật nhất định để triển khai và vận hành.
- **Splunk Enterprise Security:** Giải pháp thương mại toàn diện, mạnh mẽ, phù hợp cho doanh nghiệp lớn với khả năng xử lý lượng dữ liệu lớn và phức tạp. Điểm mạnh là khả năng phân tích và trực quan hóa dữ liệu vượt trội, tích hợp machine learning, và tự động phản hồi. Tuy nhiên, chi phí cao có thể là một rào cản.
- **OSSEC:** Giải pháp mã nguồn mở đơn giản và nhẹ, phù hợp cho triển khai quy mô nhỏ hoặc tích hợp vào hệ thống bảo mật lớn hơn. Ưu điểm là gọn nhẹ và dễ triển khai, nhưng tính năng còn hạn chế so với các giải pháp khác.
- **AlienVault OSSIM:** Giải pháp mã nguồn mở all-in-one, tích hợp nhiều tính năng SIEM, phù hợp cho tổ chức vừa và nhỏ muốn một giải pháp hoàn chỉnh và miễn phí. Tuy nhiên, khả năng mở rộng và hỗ trợ có thể không bằng các giải pháp chuyên biệt.